

TLS 연결의 양자 위협 기반 계층적 위험도 산출 모델

형유림*, 정수민*, 임다은*, 박도윤*, 조수빈*, 김재환*, 서화정*

한성대학교 (학부생, 교수*)

A Layered Risk Scoring Model for TLS Connections Against Quantum Threats

Yu-Lim Hyoung*, Su-Min Jeong*, Da-Eun Lim*, Do-Yun Park*, Su-Been Cho*, Jae-Hwan Kim*, Hwa-Jeong Seo*

Hansung University (Undergraduate student, Professor*)

요약

양자 컴퓨팅의 발전으로 TLS에서 사용되는 RSA · ECDHE 등 공개키 암호가 위협 받고 있으며, *Harvest Now, Decrypt Later*(HNDL) 공격은 양자 컴퓨터 실용화 이전에도 장기 기밀 데이터를 위협에 노출시킨다. 그러나 개별 TLS 연결의 양자 취약성을 즉각 정량화하는 체계적 방법론이 부재하다. 본 논문은 TLS 프로토콜 노출도(L1), 레거시 공개키 알고리즘 취약성(L2a), AES-128 Grover 약화(L2b), PQC Level-1 취약성(L2c), 인증서 만료 긴급도(L3)와 HNDL 전역 승수 M 으로 구성된 계층적 위험도 산출 모델을 제안하여 양자 취약성을 0~100점으로 정량화한다. 각 레이어는 독립적으로 산출되어 위험 원인의 분해(decomposition)를 가능하게 하며, 단일 점수 방식 대비 운영자의 우선순위 기반 대응을 지원한다. 또한 본 모델을 libpcap 기반 TLS 패킷 분석 도구에 적용하여 실환경에서의 동작을 검증한다.

I. 서론

양자 컴퓨팅의 발전은 TLS에서 사용되는 공개키 암호 체계에 심각한 위협을 제기하며, 특히 *Harvest Now, Decrypt Later*(HNDL) 공격은 양자 컴퓨터 실용화 이전에도 장기 기밀성이 요구되는 TLS 연결을 위협에 노출시킨다. NIST의 PQC 표준화 [1]에도 불구하고 레거시 연결 · RSA · AES-128 등 다양한 수준의 취약 연결이 공존하며, TLS 연결 파라미터를 직접 입력으로 받아 HNDL 위협을 포함한 양자 취약성을 즉각 정량화하는 방법론은 부재하다. 본 논문은 프로토콜 노출도(L1), 레거시 암호 취약성(L2a), 대칭키 약화(L2b), PQC Level-1 취약성(L2c), 인증서 만료 긴급도(L3)의 다섯 독립 레이어와 HNDL 전역 승수 M 으로 양자 취약성을 0~100점으로 정량화하는 계층적 위험도 산출 모델을 제안하고, libpcap 기반 TLS 패킷 분석 도구에 구현하여 실환경에서 검증한다.

II. 배경

2.1 TLS 프로토콜 및 양자 위협

TLS(Transport Layer Security)는 인터넷 통신의 기밀성 · 무결성 · 인증을 보장하는 표준 프로토콜로, TLS 1.0/1.1은 POODLE · BEAST 등 취약점으로 폐기 상태이며, TLS 1.2는 키 교환 방식에 따라 보안 수준이 상이하고, TLS 1.3이 현행 표준이다. RSA 키 교환은 전방향 비밀성이 없어 HNDL 공격의 직접 표적이 되며, ECDHE는 전방향 비밀성을 제공하나 이산로그 문제가 Shor 알고리즘에 취약하다. Shor 알고리즘 [2]은 RSA · ECDHE · DSA 등 공개키 암호 전반을 무력화하며, Grover 알고리즘 [3]은 AES-128의 실효 보안 강도를 64비트로 절반 감소시키는 반면 AES-256은 128비트를 유지한다.

2.2 HNDL(Harvest Now, Decrypt Later) 공격

HNDL 공격자는 현재 트래픽을 수집 · 보관하여 미래의 양자 컴퓨터로 복호화한다. RSA는 전방향 비밀성이 없어 서버 개인키 확보만으로 과거 세션 전체를 일괄 복호화할 수 있으며, ECDHE 역시 키 협상 과정이 Shor 알고리즘에 취약하다. 따라서 장기 기밀성이 요구되는 TLS 연결은 양자 컴퓨터 실용화 이전에도 이미 위협에 노출된다.

2.3 PQC 표준화 동향

NIST는 2024년 ML-KEM(FIPS 203) [1], ML-DSA(FIPS 204), SLH-DSA(FIPS 205), FN-DSA(FIPS 206)를 PQC 최종 표준으로 확정하였다. 알고리즘은 Level 1(AES-128 동등) · Level

3(AES-192) · Level 5(AES-256)로 분류되며, Level 3 이상이 충분한 양자 내성을 제공한다. Level 1은 Grover 약화를 감안하면 보수적 기준에서 충분하지 않을 수 있으며, 실제 배포에서는 기존 알고리즘과 결합한 하이브리드 방식이 채택되고 있다.

2.4 기존 연구 비교 및 차별점

CVSS v3.1 [4]은 TLS 암호 파라미터나 HNDL을 직접 반영하지 못하며, Baseri 등 [5]은 PQC 마이그레이션 단계별 정성적 위험을 산출하나 연결 단위 실시간 평가에 적합하지 않고, SQOUT [6]은 QKD 시스템 전용으로 TLS 암호 스위트 수준 분석에 적용할 수 없다. 각 연구의 비교는 표 1에 정리하였으며, 본 연구는 TLS 연결 파라미터를 직접 입력으로 받아 레이어별 점수를 독립 산출하고 HNDL 위험 연수를 연속형 승수 M 으로 정량화한다.

표 1: 기존 위험 평가 프레임워크 비교

항목	CVSS v3.1	Baseri et al.	SQOUT	본 연구
대상 도메인	범용 취약점 정량	PQC 전환	QKD 시스템 정량	TLS 연결 단위
점수 방식	0-19	정성 L/M/H	킬체인	정량 0-100
HNDL	×	개념 수준	×	M 수치화
TLS 버전별 차등	×	정성 평가	×	L1 직접 반영
인증서 만료 반영	×	정성 분석	×	L3 점수화
PQC Lv.1 취약점	×	정성 분류	×	L2c 플래그
운용 보정 m	환경 지표	×	글로벌 M	레이어별 m
Grover/AES-128	×	미반영	×	L2b 독립 산출

III. 제안 방법

3.1 설계 원칙 및 전체 구조

본 모델은 TLS 연결 하나를 평가 단위로 하며, 다섯 독립 레이어의 점수 합산 후 HNDL 전역 승수 M 을 곱하고 정규화하여 0~100 범위로 출력한다.

최종 점수 = $\left\lfloor \frac{(L1+L2a+L2b+L2c+L3) \times M}{118} \times 100 \right\rfloor$

정규화 기준값 118은 최악 조건(TLS 1.0 + RSA + AES-128 + 인증서 만료, $M = 2.0$)에서의 실질적 상한이며, 100 초과 시 클램핑한다. 파라미터 기호는 표 2에 정의한다.

표 2: 파라미터 기호 정의

기호	영문	설명
T	Threat	공격 성공 시 파괴력
E	Exposure	알고리즘·프로토콜 기본 노출도
e	Exposure Factor	네트워크 노출 범위 보정값
m	Multiplier	운용·구현·키 관리 보정 승수
M	HNDL Multiplier	HNDL 전역 승수

T 는 1(공개 도구로 즉시 공격 가능)부터 5(국가 수준 역량 필요)까지의 파괴력 척도로 운영자가 설정하며, $L2b(T=4.0) \cdot L2c(T=3.0)$ 는 고정값을 사용한다. 레이어별 m 대표값은 표 4에 정리하였다.

3.2 레이어 1: TLS 프로토콜 노출도 (L1)

$L1 = T \times E \times m$ 으로 산출하며, TLS 버전 · 키 교환 방식에 따른 E 값은 표 3과 같다. TLS 1.3 표준 연결은 $L1=0$ 이다.

표 3: L1 프로토콜별 E 값

TLS 버전	키 교환	E
1.0	—	5.0
1.1	—	4.0
1.2	RSA, 기타	2.0
1.2	ECDHE	1.5
1.3	PQC-Hybrid	1.0
1.3	—	0

3.3 레이어 2: 암호 알고리즘 취약성 (L2a, L2b, L2c)

각 서브레이어는 독립적 발동 조건을 가지며, 미충족 시 해당 점수는 0이다.

3.3.1 L2a: 레거시 공개키 알고리즘 취약성

Shor 알고리즘에 취약한 레거시 키 교환 연결에 적용된다. $L2a = T \times E \times e \times m$ 이며, RSA는 전방향 비밀성 부재로 $E=5.0$, ECDHE/DHE는 $E=3.0$ 을 적용한다. e 는 로컬(0.25) · 내부망(0.50) · 인터넷 443 포트(1.00)이다.

3.3.2 L2b: AES-128 Grover 약화

AES-128 사용 연결에 적용되며 AES-256은 발동하지 않는다. $L2b = T \times E \times m$ 이며, $T=4.0$, $E=0.5$ 로 고정한다.

표 4: 레이어별 환경 보정 승수 m 대표값

레이어	보정 기준	완화 ($m < 1$)	기본 증가 ($m > 1$)
L1	다운그레이드 방어	0.6 (HSTS+Pinning)	1.0
L2a	키 관리 정책	0.6 (HSM+키 회전)	1.0
L2b	세션·KDF 설계	0.7 (단기+HKDF)	1.0
L2c	PQC 구현 품질	0.6 (CT 구현 검증)	1.0

3.3.3 L2c: PQC Level-1 취약성

PQC 하이브리드 사용 중 해당 알고리즘이 NIST Level-1이며 운영자가 pqc level1 vulnerable=1로 활성화한 경우에만 발동한다. $L2c = T \times E \times m$ 이며, $T=3.0$, $E=2.0$ 으로 고정한다.

3.4 레이어 3: 인증서 만료 긴급도 (L3)

인증서 정보가 가용한 경우 만료까지 남은 일수 d 에 따라 산출하며, m 은 적용하지 않는다.

$$L3 = \begin{cases} 5.0 & d < 0 \\ 5.0 \times \frac{30-d}{30} & 0 \leq d < 30 \\ 0 & d \geq 30 \end{cases}$$

3.5 HNDL 전역 승수 M

M 은 기밀 유지 기간 h (년)를 반영하는 전역 승수로, 모든 레이어 합산 후 곱해진다. $h=0$ 이면 $M=1.0$, $h=20$ 이면 $M=2.0$ 이다.

$$M=1.0+\frac{h}{20.0}, M \in [1.0, 2.0]$$

IV. 실험 및 평가

제안 모델의 유효성을 두 가지 실험 질문으로 검증한다.

- **RQ1:** 레이어별 분해 정량화가 의미 있는가?
- **RQ2:** 국내외 기업 간 위험도 차이를 유의미하게 반영하는가?

4.1 실험 환경

본 실험은 Cho 등 [7]이 제안한 양자 취약 TLS 자동 분석 프레임워크를 기반으로 수행되었다. 해당 프레임워크는 패킷 검사를 통해 TLS 연결의 암호 파라미터를 자동으로 추출하며, 본 논문의 위험도 산출 모델을 해당 프레임워크에 적용하여 실험 환경 검증을 수행하였다. Windows 11 및 Kali Linux 환경에서 WinPcap/libpcap으로 패킷을 캡처하고 OQS OpenSSL을 활용하였다. 국내외 주요 기업 20개사에서 총 123개 TLS 세션(SNI 기준, 국내 70 · 글로벌 53)을 수집하였으며, 외부 관측 불가 파라미터는 $m=1.0$, $e=1.0$ 으로 고정하고 $h=10$ ($M=1.50$)을 적용하였다.

4.2 RQ1: 레이어별 점수 분포 분석

123개 세션의 레이어별 평균 점수는 표 5와 같다. L2a에서 국내(64.3%) 대비 글로벌(49.1%)의 RSA/ECDHE 사용 비율 차이가 점수 차로 드러났으며, L2c는 전 세션에서 ML-KEM-768 (Level-3)이 사용되어 0점으로 처리되었다.

4.3 RQ2: 국내외 기업 위험도 비교

$M=1.50$ 적용 시 국내 평균 17.74점, 글로벌 14.64점으로 3.1점 차이가 나타났다. 국내 금융권 RSA 유지 도메인에서 L2a 최댓값이 산출되어, HNDL 시간적 위험 차원이 국내외 격차를 정량적으로 드러냄을 확인하였다.

표 5: 레이어별 평균 점수 분포 (123개 세션)

레이어	발동 조건	국내 평균	글로벌 평균	전체 평균
L1	TLS 버전·키 교환	1.91	1.78	1.85
L2a	RSA/ECDHE 사용	7.33	5.21	6.42
L2b	AES-128 사용	1.49	1.36	1.43
L2c	PQC Level 1	0.00	0.00	0.00
L3	인증서 만료 임박	0.81	1.19	0.97

V. 결론

본 논문은 TLS 연결의 양자 취약성을 0~100점으로 즉각 정량화하는 계층적 위험도 산출 모델을 제안하였다. 다섯 레이어의 독립적 분해를 통해 위험 원인을 구체적으로 식별하고, HNDL 위험의 시간적 차원을 연속형 전역 승수 M 으로 최종 점수에 직접 반영한다는 점에서 기존 CVSS · Baseri · SQOUT 방식과 명확히 차별화된다. 실험 환경 적용 결과 국내 평균 17.74점, 글로벌 14.64점으로 격차가 정량적으로 확인되었으며, 국내 인터넷 인프라의 PQC 전환이 시급함을 입증하였다. 향후 과제로는 기계 학습을 통한 환경 보정 승수 m 의 자동 추정과, 더 많은 도메인 · 세션 및 QUIC 등 TLS 1.3 내장 프로토콜로 검증 범위를 확장하는 방향을 고려한다.

VI. Acknowledgment

This work was supported by Institute of Information & communications Technology Planning & Evaluation (IITP) grant funded by the Korea government(MSIT) (No.RS-2025-02306395, Development and Demonstration of PQC-Based Joint Certificate PKI Technology, 40%) and this work was supported by the Institute of Information & Communications Technology Planning & Evaluation(IITP) grant funded by the Korea government(MSIT) (No. RS-2025-25394739, Development of Security Enhancement Technology for Industrial Control Systems Based on S/HBOM Supply Chain Protection, 40%) and this work was supported by the IITP(Institute of Information & Communications Technology Planning & Evaluation)-ITRC(Information Technology Research Center) grant funded by the Korea government(Ministry of Science and ICT)(IITP-2026-RS-2020-II201797, 20%).

[참고문헌]

[1] National Institute of Standards and Technology,

- “FIPS 203:Module-lattice-based key-encapsulation mechanism standard,” tech. rep., NIST, 2024.
- [2] P. W. Shor, “Algorithms for quantum computation: Discrete logarithms and factoring,” Proceedings of the 35th Annual Symposium on Foundations of Computer Science, 1994.
- [3] L. K. Grover, “A fast quantum mechanical algorithm for database search,” in Proceedings of the 28th Annual ACM Symposium on Theory of Computing, 1996.
- [4] FIRST.Org, “Common vulnerability scoring system version 3.1: Specification document,” tech. rep., FIRST, 2019.
- [5] Y. Baseri, V. Chouhan, A. Ghorbani, and A. Chow, “Evaluation framework for quantum security risk assessment: A comprehensive strategy for quantum-safe transition,” arXiv preprint arXiv:2404.08231, 2024.
- [6] M. Krelina, T. Sorger, and B. Dirks, “SQOUT: A risk-based threat analysis framework for quantum communication systems,” arXiv preprint arXiv:2510.23462, 2025.
- [7] S.-B. Cho, Y.-L. Hyoungh, H. Kim, M. Sim, A. Chattopadhyay, H.-J. Seo, and H. Kim, “Toward crypto agility: Automated analysis of quantum-vulnerable TLS via packet inspection,” in International Conference on Security, Privacy, and Applied Cryptography Engineering, (Cham), pp. 114 - 133, Springer Nature Switzerland, Dec. 2025.